Zusatzübungen 21 – Agenten sicher betreiben

Zum Cheatsheet: `01_cheatsheets/21_agenten_sicherheit`

Stufen: ★ Einstieg · ★★ Alltag · ★★★ Herausforderung **Regel:** Nutze nur erfundene oder anonymisierte Daten. Alle Aufgaben funktionieren mit jedem KI-Dienst und im Free-Plan. Lösungsansätze stehen am Ende. Schau erst nach, wenn du fertig bist.

Aufgabe 1 ★ – Checkliste anwenden

Ausgangslage: Ein fiktiver Kalender-Agent soll Termine vorschlagen und eintragen.

Aufgabe: Beantworte für diesen Agenten die fünf Prüfpunkte der Checkliste „Vor dem ersten Einsatz“: Rechte, Limits, Freigaben, Backup, Notaus. Je Punkt ein bis zwei Sätze.

Hinweis: Denk an das Prinzip: Lesen vor Schreiben, so wenig wie möglich.

Aufgabe 2 ★ – Minimale Rechte finden

Ausgangslage: Ein Datei-Agent soll PDFs in einem Ordner sortieren.

Aufgabe: Welche dieser Rechte braucht er wirklich (J/N) und warum? - a) Lesen aller PDFs im Zielordner - b) Schreiben in denselben Ordner (verschieben/umbenennen) - c) Vollzugriff auf alle Ordner der Festplatte - d) Internetzugang - e) Zugriff auf deine Mails

Hinweis: Jedes zusätzliche Recht ist eine Angriffsfläche (Thema 12). Frage bei jedem: Was bricht, wenn der Agent es missbraucht?

Aufgabe 3 ★★ – Der Fehlerfall

Ausgangslage: Ein fiktiver Mail-Agent hat versehentlich eine unfertige Antwort an 30 Empfänger gesendet (erfundene Situation).

Aufgabe: Gehe deinen Notfall-Fahrplan durch: Was tust du in den ersten fünf Minuten? Was danach? Nenne konkrete Schritte: Mail zurückrufen (falls möglich), Folgemail korrigieren, Ursache finden, Zugriffe anpassen, Protokoll prüfen.

Hinweis: Der Fahrplan muss vor dem Vorfall stehen – schreibe ihn so, wie du ihn im Stress abrufen würdest.

Aufgabe 4 ★★ – Testumgebung bauen

Ausgangslage: Du willst einen Datei-Sortier-Agent ausprobieren, hast aber nur echte Dateien.

Aufgabe: Plane eine Testumgebung: (1) Wie erstellst du eine sichere Testumgebung mit erfundenen Dateien (z. B. leere Testordner mit Dummy-Dateien)? (2) Welche drei Tests führst du zuerst durch? (3) Wann würdest du den Agenten an echte Dateien lassen – und mit welchen Einschränkungen?

Hinweis: Die Testumgebung simuliert den Ernstfall, aber ohne echten Schaden. Ein Testkonto statt echtem Konto gehört dazu.

Aufgabe 5 ★★★ – Sicherheits-Fahrplan für ein eigenes Projekt

Ausgangslage: Du hast einen echten (oder fiktiven) Agenten-Anwendungsfall aus deinem Alltag.

Aufgabe: Erstelle den kompletten Sicherheits-Fahrplan: (1) Checkliste „Vor dem ersten Einsatz“ ausgefüllt. (2) Notfall-Fahrplan (wie Aufgabe 3). (3) Prüfplan: Was schaust du nach dem ersten, nach dem fünften und nach dem zwanzigsten Lauf an? (4) Abbruchkriterium: Wann schaltest du den Agenten ab?

Hinweis: Die Abbruchkriterien sind oft vergessen: Definiere vorab, welches Verhalten unakzeptabel ist (z. B. eine einzige unbestätigte Aktion mit Folgen reicht zum Stopp).

Transfer (optional)

Was ist dein persönlich wichtigster Sicherheitspunkt beim Agenten-Einsatz – und warum? Schreibe ihn auf und hänge ihn an sichtbarer Stelle in deine Notizen.

Lösungsansätze

Aufgabe 1: Beispiel: **Rechte** – Kalender lesen (alle Termine), Termine nur als Entwurf/Vorschlag anlegen, kein Löschen. **Limits** – max. 10 Vorschläge pro Lauf, nur für die kommende Woche, max. 5 Minuten Laufzeit. **Freigaben** – Jedes Eintragen und jede Einladung bestätigt der Mensch. **Backup** – Kalender vor dem ersten Lauf exportieren; Terminänderungen müssen rückholbar sein. **Notaus** – Verbindung trennen, Agent stoppen, Zugriffe in den Kontoeinstellungen widerrufen.

Aufgabe 2: a) Ja – Kern der Aufgabe. b) Ja, wenn das Sortieren das Ziel ist – aber auf genau diesen Ordner begrenzt. c) Nein – Vollzugriff auf alles ist niemals nötig und die maximale Angriffsfläche. d) Nein – PDFs sortieren braucht kein Internet; Internetzugang öffnet Injection-Wege. e) Nein – hat mit der Aufgabe nichts zu tun.

Aufgabe 3: Beispiel-Fahrplan: **Erste 5 Minuten:** Versenden weiterer Mails stoppen (Agent pausieren/stoppen), prüfen, ob mehr als eine Mail betroffen ist, ggf. Empfänger nicht verunsichern, bevor du Fakten hast. **Danach:** Rückruf oder Korrekturmail senden (kurz, sachlich, richtiges Dokument), Protokoll prüfen (Was genau hat der Agent getan? Wann?), Ursache finden (z. B. zu große Rechte, fehlende Freigabe), Zugriffe anpassen, Testlauf in der Testumgebung, dann erst wieder aktivieren.

Aufgabe 4: (1) Neuen leeren Ordner „Test“ anlegen mit 5–10 erfundenen PDF-Dateien (Dummy-Namen); Agent nur auf diesen Ordner beschränken, idealerweise mit Testkonto. (2) Erste Tests: (a) Normalfall – sortiert der Agent korrekt? (b) Sonderfall – was passiert mit einer untypischen Datei? (c) Fehlerfall – Verhalten bei doppelten Namen oder schreibgeschützter Datei. (3) Echte Dateien erst, wenn alle Tests sauber laufen – dann zunächst mit Kopien statt Originalen, minimalen Rechten und Freigaben vor jeder Änderung.

Aufgabe 5: Individuelle Lösung. Gute Antworten enthalten: ausgefüllte Checkliste (Rechte, Limits, Freigaben, Backup, Notaus), einen Schritt-für-Schritt-Notfallplan mit konkreten Orten (wo widerrufe ich, wo stoppe ich), einen Prüfplan (1. Lauf: komplett mitlesen; 5. Lauf: Stichprobe; 20. Lauf: wöchentlich Protokoll), und klare Abbruchkriterien wie „eine einzige unbestätigte Aktion mit Folgen = sofortiger Stopp + Rechte-Review“.

Weiter: Cheatsheet 22 (Recht & Compliance), Test E (`03_tests/test_E_agentische_systeme`)

Stand: Oktober 2026